

Progetto S3 L5

Brevi cenni teorici:

Un **firewall** è un dispositivo di sicurezza informatica (hardware o software) deputato a filtrare il traffico dati tra reti con diversi livelli di fiducia, agendo come barriera perimetrale.

I firewall si dividono principalmente in due categorie logiche:

- **Stateless (Packet Filter):** Analizza i singoli pacchetti in modo isolato, controllando unicamente le informazioni statiche contenute negli header (indirizzi IP sorgente/destinazione, porte e protocolli). Non ha memoria del contesto o delle comunicazioni passate.
- **Stateful (Stateful Packet Inspection - SPI):** È la tecnologia utilizzata da apparati come **pfSense**. Questo approccio monitora lo stato delle connessioni attive inserendole in una State Table (tabella degli stati). Se una sessione iniziale è legittima e approvata dalle regole, tutti i pacchetti successivi appartenenti allo stesso flusso vengono fatti transitare automaticamente, garantendo maggiore sicurezza e prestazioni superiori rispetto ai sistemi stateless.

Esercizio:

Passo 1: Configurazione su Virtual Box

Configuriamo le 3 macchine (Kali Linux, Metaspotable e Pf Sense) su Virtual Box.

-Kali Linux:

 **Network**

Adapter 1: Intel PRO/1000 MT Desktop (Internal Network, 'kalinet')

impostata su rete interna chiamata 'Kalinet'

-Metaspotable:

 **Network**

Adapter 1: Intel PRO/1000 MT Desktop (Internal Network, 'Metanet')

Impostata su rete interna chiamata 'Metanet'

-PfSense:

 **Network**

Adapter 1: Paravirtualized Network (NAT)
Adapter 2: Paravirtualized Network (Internal Network, 'kalinet')
Adapter 3: Paravirtualized Network (Internal Network, 'Metanet')

Qui troviamo 3 schede di rete

Adapter 1: configurata in NAT perchè ci permette di comunicare con il “mondo esterno” (Internet)

Adapter 2: configurata su kalinet in modo da isolarla

Adapter 3: configurata su Metanet in modo da isolarla.

Passo 2: Configurazione su PfSense

Avviamo le tre macchine, che dovranno rimanere accese per tutto il tempo, ma ci concentriamo su PfSense, dobbiamo, come primo step, configurare le porte e assegnamo alla **vtnet 0** l'interfaccia **WAN**(internet), **vtnet1** la **LAN**(rete della Kali) e **vtnet2** la **OPT1**(rete della Metaspotable).

Dopo aver assegnato le interfacce dobbiamo settare gli indirizzi IP

vtnet0(WAN): essendo impostata su NAT l'indirizzo IP l'abbiamo assegnato tramite protocollo **DHCP (10.0.2.15/24)**

vtnet1(LAN): abbiamo impostato l'IP manualmente abilitando il server DHCP sulla LAN dando un range di IP **(192.168.10.1/24 con range che va .201 a .220)**

vtnet2(OPT1): l'abbiamo impostato manualmente **(192.168.50.1/24)**

```
The IPv4 LAN address has been set to 192.168.10.1/24
You can now access the webConfigurator by opening the following URL in your web
browser:
    http://192.168.10.1/

Press <ENTER> to continue.
VirtualBox Virtual Machine - Netgate Device ID: 679e36312edce85c5ff6

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> vtnet0      -> v4/DHCP4: 10.0.2.15/24
LAN (lan)      -> vtnet1      -> v4: 192.168.10.1/24
OPT1 (opt1)    -> vtnet2      -> v4: 192.168.50.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option: 
```

Controlliamo se abbiamo configurato bene le interfacce andando sui terminali di Kali e Metaspotable e troviamo i seguenti IP assegnati:

Kali: 192.168.10.201

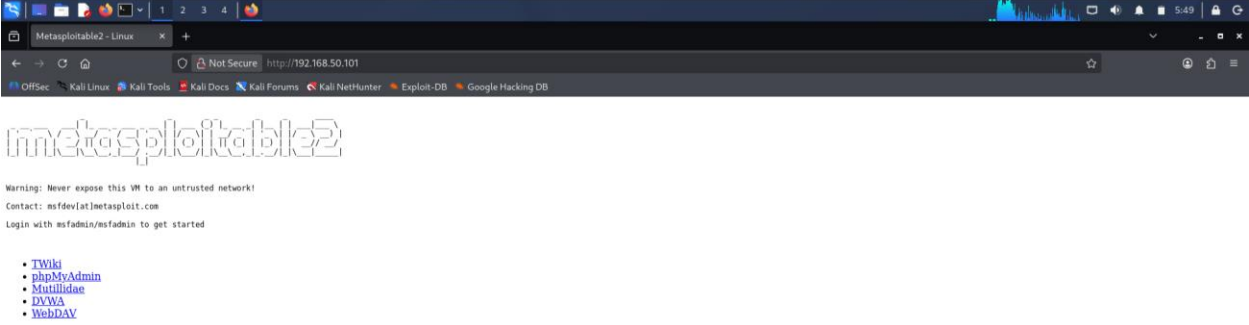
Metaspoitable: 192.168.50.101

Le macchine sono isolate sulle loro reti, ma riescono a comunicare correttamente attraverso il PfSense che fa da router, proviamo sia ad usare il comando su terminale **ping** da Kali verso Metaspotable sia ad accedere da browser della Kali sulla pagina di Metaspotable per confermare la giusta configurazione:

Ping:

```
(kali@kali)-[~]
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=63 time=11.6 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=63 time=4.19 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=63 time=21.5 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=63 time=10.7 ms
^C
— 192.168.50.101 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 4.186/12.015/21.517/6.192 ms
```

Browser:



Passo 3: -Configurazione su PfSense

Dalla Kali apriamo il browser e inseriamo l'indirizzo di gateway che è associato alla PfSense (192.168.10.1), si aprirà l'interfaccia del login di PfSense dove andremo ad accedere. Una vota dentro andiamo su **“Firewalls->Rules”** Troviamo tre sezioni (WAN, LAN, OPT1) ciascuna con le proprie regole (rules). Per l'esercizio ci interessa modificare solo le regole della LAN(Kali) verso OPT1(Metaspotable), notiamo

che sulla LAN abbiamo già tre rules di default abilitate in “pass”, la prima è praticamente fissa, non può essere eliminata, modificata o spostata, è quella regola che ti da accesso alla WebGUI con porta 80(HTTP) della PfSense in modo che commettendo un qualsiasi errore in una regola potremmo sempre accedere alla WebGUI per poter sistemare l’errore, le altre due regole sono un lascia passare per gli IPv4 e IPv6 e si mantengono sempre in fondo alla lista .

Inseriamo la nostra regola sotto la regola di default principale, con le seguenti configurazioni:

Edit Firewall Rule

Action

Block

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

LAN

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

TCP

Choose which IP protocol this rule should match.

Source

Source

☐ Invert match

Address or Alias

192.168.10.201

/

Display Advanced

The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination

☐ Invert match

Address or Alias

192.168.50.101

/

Destination Port Range

HTTP (80)

From

Custom

HTTP (80)

To

Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log

☒ Log packets that are handled by this rule

Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description

A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

Advanced Options

Display Advanced

Salviamo e applichiamo la regola.

Adesso le liste di regole risulteranno:

WAN:

FloatingWANLANOPT1

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒		0/0 B	*		RFC 1918 networks	*	*	*	*	Block private networks	
☒		0/0 B	*		Reserved Not assigned by IANA	*	*	*	*	Block bogon networks	

No rules are currently defined for this interface
All incoming connections on this interface will be blocked until pass rules are added. Click the button to add a new rule.

LAN:

FloatingWANLANOPT1

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		1/610 KIB	*	*	LAN Address	80	*	*		Anti-Lockout Rule	
☐		0/23 KIB	IPv4 TCP	192.168.10.201	*	192.168.50.101	80 (HTTP)	*	none		
☐		0/199 KIB	IPv4 *	LAN subnets	*	*	*	*	none	Default allow LAN to any rule	
☐		0/0 B	IPv6 *	LAN subnets	*	*	*	*	none	Default allow LAN IPv6 to any rule	

OPT1:

FloatingWANLANOPT1

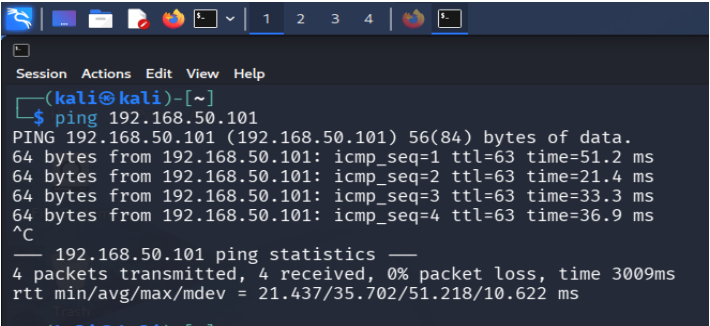
Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
No rules are currently defined for this interface All incoming connections on this interface will be blocked until pass rules are added. Click the button to add a new rule.											

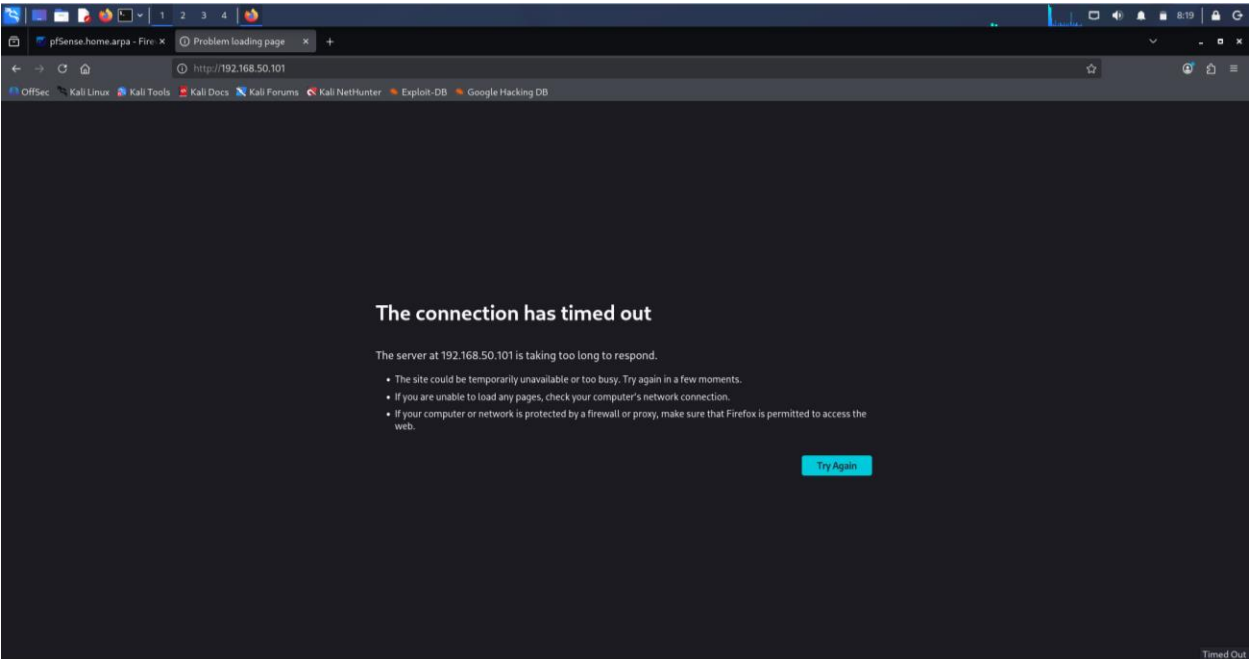
Tutto configurato adesso testiamo se la regola che abbiamo introdotto sia effettivamente funzionante, come fatto in precedenza, per testare se la Kali e la Metaspotable comunicano fra di loro abbiamo usato il comando ping da terminale su Kali e da browser, sempre da Kali, abbiamo provato ad aprire la pagina di Metaspotable.

Dopo la configurazione della regola vediamo i seguenti risultati:

Ping:



Browser:



Conclusioni

In conclusione, l'attività di laboratorio è stata completata con successo, focalizzandosi su un principio fondamentale della network security: il controllo granulare del traffico. Tramite il firewall pfSense, l'accesso della macchina attaccante (Kali Linux) verso la macchina vulnerabile (Metasploable) è stato limitato in modo selettivo, bloccando i servizi web ma mantenendo la raggiungibilità diagnostica della rete.

L'analisi dei risultati ha permesso di consolidare i seguenti concetti chiave:

- Filtraggio basato su Porte e Protocolli:** A differenza di un blocco totale (any), l'applicazione di una regola specifica sul protocollo TCP e sulla porta 80 (HTTP) ha dimostrato come un firewall possa inibire una specifica applicazione (l'accesso alla piattaforma DVWA) senza isolare completamente l'host di destinazione.
- Differenziazione dei Protocolli (TCP vs ICMP):** Il successo del test ha confermato la logica "Top-Down" di PfSense. Il traffico web interseca la prima regola in cima alla lista e viene bloccato (**Block**). Al contrario, il comando ping, basandosi sul protocollo **ICMP**, non corrisponde ai criteri della regola restrittiva; il pacchetto scende quindi verso la regola di default venendo inoltrato correttamente e permettendo la ricezione delle risposte.
- Bilanciamento tra Sicurezza e Diagnostica:** Questo scenario riflette una configurazione tipica aziendale, in cui si sceglie di bloccare l'esposizione di servizi critici o vulnerabili a determinati host, lasciando però attivo il protocollo ICMP per consentire agli amministratori di rete di verificare lo stato di "up/down" della macchina tramite un semplice ping.